

Pro-Computing & Ethic (PCE)

PDF 0 : Introduction

▼ What to expects from the class ?

Enabling you to mitigate and reduce risk or casualty after being attacked

▼ Our target Audience

▼ Security Newcomers

- Early-career professionals
- Business-focused learners
- Those seeking to understand ISMS value

▼ Security Experts

- Security professionals
- Leadership teams
- Those requiring executive buy-in

▼ Core Objectives

▼ Establish Security as a Strategic Investment

- Return on Investment (ROI)
- Aligning what business needs and make good used of every investment to gain profits

▼ Develop Robust Security Governance

Policy and Strategy must be implemented by the following :

▼ Mission Alignment

- Learn company goal to make best use of security strategy

▼ Strategic Integration

- Aligning security function to fit organization goals and mission

▼ Due Diligence Implementation

- Take policies to demonstrate due diligence and due care

▼ Documentation Framework

- Defining Security which include policies, standards, procedure and guidelines

▼ Organisational Structure

- Enforce role and responsibilities
- ▼ Risk Management & Asset Protection
 - Learning qualitative and quantitatively analysis to identify threats, vulnerabilities and prioritise response effectively
 - Understand CIA Triad
 - Asset Classification
 - Security Controls including Defence in Depth and Zero Trust
- ▼ Ensure Legal & Regulatory Compliance
 - Privacy and Data laws : Data Sentinel
 - Third-Party Risk : Contract with 3rd party software might be risky
 - Compliance Programmes : Take country law and apply in company
- ▼ Cultivate Human Capital & Resilience
 - Security Awareness Programmes
 - Social Engineering Defence
 - Incident Response Planning (preparation, detection, analysis, response and recovery)

PDF 1 : Security Governance, Risk Management and Ethics Foundation

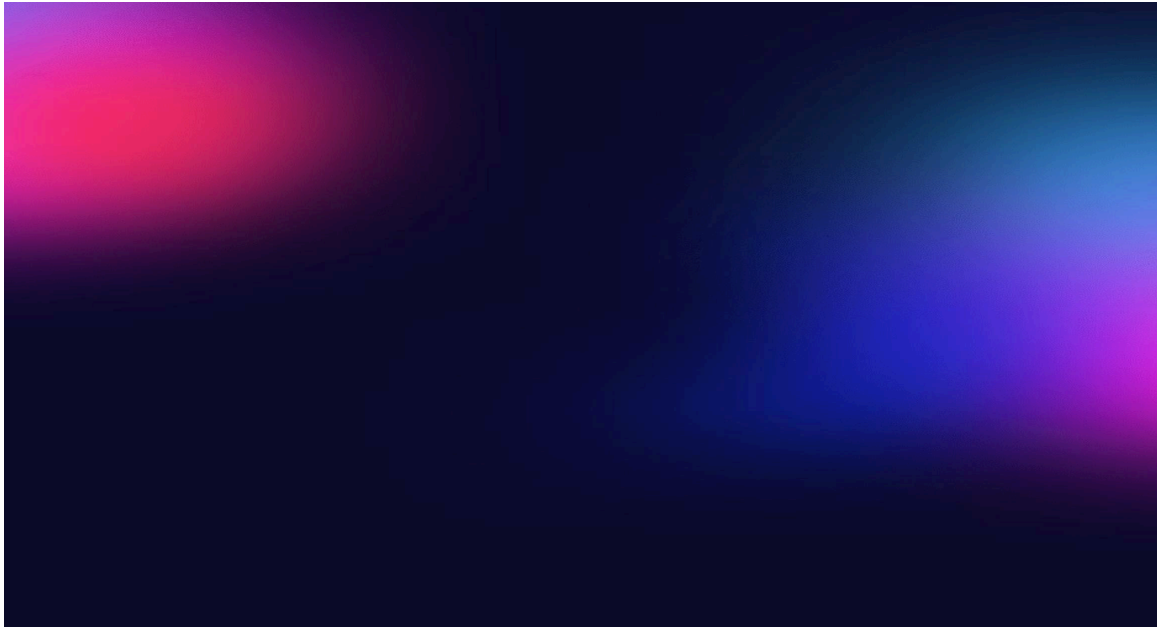
Strategic aligning information to apply risk methodologies

▼ Governance, Documentation and Risk Strategy

Clear Function and procedure which leads to better maintaining and oversight of accountabilities

1. Align Security with Business Objectives

- Safeguard Action (SA) : Ensure security functions aligning with the need of strategy, goals, mission and objectives
- Implementation Step (IS) : Defining scope and context
- Best Practice Value/Impactful (BPVI) : Make every cost counts and guaranteed security efforts support business



2. Establish a Formal Policy Structure

- SA : Using documents which has standard to set the minimum security level and requirements and details it with "How to" mind set
- BPVI : Clarify, Consistency and Adaptability

3. Define And Assign Accountability

- SA : Determine role and responsibilities (GV.RR) often include Data owner (Defining Classification), Custodian (protection/implementation) and users
- BPVI : Traceable to maintain accountability
 - Data owner : Defining classification
 - Custodian : Protection/Implementation
 - Users : Day-to-day Operations

Implementing an Information Security Management System

4. Adopt a Recognised Management Framework

- SA : Use a globally recognised standard like ISO 27001:2013 to establish, implement and maintain
- BPVI : To grant trust and respected certification to stakeholders

5. Integrate Compliance Requirements

- SA : Apply rule and regulations compliance align with country laws. MLPS to have multiple layer security when dealing with information through network
- BPVI : Ensure the systems meet baseline security (Legality, Propriety and Necessity)

6. Demonstrate Due Diligence and Due Care

- SA : Make Strategic plans to maintain security, align with the rule
- BPVI : Show maintain management and its procedures which is crucial for preventing legal liabilities and criminal prosecution related to breaches

Formal Risk Management Practices (Identify Function)

7. Perform Risk Assessment Based on CIA

- SA : Conduct CIA which include concepts like authenticity and nonrepudiation
- BPVI : Focus on the main asset which include financial, personal and contracts

▼ 8-10. Advance Risk Management Implementation

Advanced Risk Management & Quantitative Analysis

- Quantitative Risk Analysis (Quantify Exposure): Uses objective, financial data to calculate Annualized Loss Expectancy (ALE) and justify security spending.
 - Calculation: $ALE = SLE \times ARO$, where SLE (Single Loss Expectancy) = AV (Asset Value) $\times$ EF (Exposure Factor).
 - Steps: Inventory assets (AV), calculate EF and SLE for each asset-threat pairing, determine ARO (Annualized Rate of Occurrence), and calculate ALE.
- Manage Supply Chain Risk (SCRM): Assess and monitor third parties and ensure written agreements define security responsibilities.
- Apply Risk Treatment (Controls): Select countermeasures—mitigation, transfer, avoidance, or acceptance. Implement preventive, detective, and corrective controls to reduce total risk to acceptable residual risk using a Defence in Depth strategy.

▼ CMMC Level 1 Practices (Basic Cyber Hygiene)

These practices protect Federal Contract Information (FCI) across six domains:

- Access Control (AC) & Identification and Authentication (IA): Limit access to authorized, identified, and authenticated users.
- Media Protection (MP): Protect, limit access to, sanitize, and destroy physical and digital media containing FCI.
- Physical Protection (PE): Limit and log physical access to systems and equipment; escort visitors.
- System and Communications Protection (SC): Monitor and protect communications at system boundaries; use separated subnetworks for public-facing components.
- System and Information Integrity (SI): Identify and correct flaws; provide and update malicious code protection; perform system and real-time file scans.

Processing personal information must adhere to three core principles:

1. Legality: Requires a valid legal basis and compliance with all applicable laws and regulations.
2. Propriety: Must be legitimate, justified, and transparent; processing methods must be appropriate.
3. Necessity: Must adhere to data minimization principles, collecting and processing only the minimum amount of data essential to achieve the stated purpose.

PDF 2 : Asset Security And Data Protection Lifecycle

Part 1 Foundation - Data Governance & Classification

▼ Data Governance

A system to trace down who own the data for accountabilities

▼ Establishing Your Data Management Process

▼ Create Central Policy and address :

- Data sensitive levels
- Ownership assignment
- handling procedure
- retention requirements
- disposal procedures

▼ Establish Review Cycles

- New regulations affect the industry

- Major security incident happen
- Technology infrastructure changes substantially
- significant business changes occur (Merge , new product)
- ▼ Ensure policy distribution
 - make policies accessible
 - require ack during onboarding
 - provide regular training updates
 - maintain version control
- ▼ Defining Data and Role Accountability
 - ▼ Data Owner
 - Responsibility : accountability for specific data sets
 - ▼ Duties
 - determines data classification levels
 - give access only those needs
 - approve access requests
 - set retention and handling requirements
 - bears responsible for data breach involving their data
 - ▼ Role
 - Business unit leaders
 - department heads
 - process owners
 - ▼ Data Custodian
 - ▼ Responsibility
 - Technical Implementation
 - Maintenance of Records
 - ▼ Duties
 - Implements Security control specified by data owner
 - perform backup regular
 - maintain system configuration
 - monitor access logs
 - applies patches and updates
 - ▼ Role
 - IT administration
 - Database Administration
 - System Engineers

- ▼ Data Processor/Controller
 - ▼ Responsibility
 - Handling data with owner instruction
 - ▼ Duties
 - Process data only as authorized
 - implement contractual security requirements
 - report security incidents to the data owner
 - Ensure compliance with regulation
 - Maintain processing records
 - ▼ Role
 - Third party vendor
 - cloud service provider
 - outsourced services
- ▼ Establishing Data Classification Scheme
 - ▼ Government/Military Classification Levels
 - Top secret
 - There's no data about it
 - ▼ Sensitive
 - financial records
 - health records
 - authentication credentials
 - ▼ required controls
 - Encryption at rest and in transit
 - 2FA
 - strict access
 - DLP monitoring
 - Audit logging all the time
 - Secure disposal requirements
 - ▼ Confidential
 - Internal policies and procedure
 - employee directory information
 - internal project documentation
 - non-public financial data
 - vendor contracts
 - ▼ required controls

- access control based on duty
- basic encryption for remote access
- stand backup procedure
- controlled sharing with third parties

▼ Public

- marketing materials
- published financial statements
- press release
- product documents

▼ required controls

- integrity protection
- version control
- basic access control prevent unauthorized editing

▼ Maintaining Data Inventory and Mapping Data Flows

Data Inventory

A **Data Inventory** documents specific data types (e.g., email addresses) and key details like its **sensitivity classification**, **owner**, **location**, **retention period**, and applicable **regulations** (GDPR, HIPAA).

- **Priority:** Start by focusing on **sensitive data** and data subject to regulatory requirements.
- **Purpose:** You can't protect what you don't know you have.

▼ Mapping Data Flows

Mapping Data Flows creates a visual diagram showing how data moves from its **source** (collection) through all **processing points**, **storage locations**, and **third-party transfers** until **disposal**.

- **Why it's Crucial:** Mapping helps **identify security gaps** (where encryption is missing), define system **security boundaries**, and **scope compliance efforts**.
- **Impact:** A major cause of security incidents is organizations not knowing where their sensitive data is stored. An accurate inventory and map prevent this "**shadow data**" from being breached

Part 2 : Technical Controls Protecting Data in All States

▼ State of data

- Data at rest : Stored in hard drive, SSD, Database, Backup, Archive
- Data in Transit : Moving across networks between network internet
- Data in use : Actively processed in memory RAM or CPU

▼ Access Controls : Least Privilege Foundation

Access Controls enforce the Need to Know (access only required data) and Least Privilege (minimum necessary permissions) principles.

▼ Implementation Steps:

1. Role-Based Access Control (RBAC): Group users into defined roles and assign permissions to the role, not the individual.
2. Configure ACLs: Set precise permissions on files, databases, and applications, often using network segmentation to restrict system access.
3. Regular Access Reviews: Conduct frequent checks (e.g., quarterly) to remove access immediately when roles change and document all decisions.
4. Separation of Duties: Divide critical functions (e.g., initiator and approver) so no single person controls a sensitive process.

▼ Encryption Data at Rest

▼ Where to encrypt

- Full-disk encryption (FDE) : BitLocker , FileVault and Luks
- Infrastructure: Encrypt sensitive file shares, databases, VM images, and backups.

▼ Encryption Approach

▼ FDE

Encrypt Entire Disk

- Pro
 - Simple to implement
 - protect all data
 - good for isolation device
- Con
 - Doesn't protect when machine is running
 - all data decrypted when disk is mounted
 - doesn't protect against compromised OS

▼ File-Level Encryption

Encrypt Individual Files or Folders

- Pro
 - control over what's encrypted
 - different key different file
 - protection persists when files are move
- Con
 - User must remember to encrypt file
 - management overhead
 - metadata may remain visible

▼ Database Encryption

Database encryption data files on disk

- Pro
 - Transparent to application
 - No code changes needed
 - protect against storage theft
- Con
 - Data will decrypt when access
 - No protection against SQL injection
 - Data Admin can access plaintext

▼ Application Layer Encryption

Encrypt specific data fields before storing in database

- Pro
 - Data remains encrypted in database
 - DBAs Cannot read sensitive field
 - Protected against database compromises
 - High sensitive data
- Con
 - Requires code changes

- Complex to implement
- Can impact database performance

▼ Cryptographic Standard

- Use FIPS 1402/1403 validated
- Algorithm : AES-256, RSA-2048 or higher
- Minimum : AES-128 or stronger
- Recommend : AES-256
- Key Management : Cryptographic keys must be protected with strong access controls

▼ Key management best practices

1. Separate keys from encrypted data
2. Use key management system
3. Implement key rotation
4. Protect key access
5. Establish Key recovery procedures
6. Document key lifecycle

▼ Encryption Data In Transit

▼ Purpose : Prevent eavesdrop and tampering

- External
 - Web Traffic (HTTPS)
 - Email (S/MIME, PGP)
 - File Transfer (SFTP, FTPS)
 - Remote Access (VPN)
 - API communications
 - Payment
- Internal
 - Database Connection
 - Server-to-Server Communications
 - Wireless Networks
 - Admin Access

┆ Encrypt to minimize the damage upon breached

▼ Configuring Best Practice

- Use strong cipher suites (AES-GCM preferred)
- Disable weak cipher (RC4, DES, 3DES)

- Enable Perfect Forward Secrecy (PFS)
 - Uses certificate from trusted authority (CAs)
 - Implement Certificate pinning for critical application
 - Monitor certificate expiration
- ▼ SSH (Secure Shell)
- **Standard:** OpenSSH
 - **Use cases:** Remote administration, SFTP/SCP for secure file transfer
 - **Best practices:** Disable password authentication when possible, use key-based authentication with passphrases, restrict root login
- ▼ VPNs & IPsec
- **Options:** SSL/TLS VPNs (easier deployment), IPsec (stronger security for high-risk environments)
 - **Configuration:** Require MFA, prefer always-on VPN for sensitive remote work, avoid split-tunnel configurations unless necessary
 - **Monitoring:** Review VPN logs regularly for anomalies and unauthorized access attempts
- ▼ Protecting Authentication & Sensitive Data in Transit
- **Must encrypt:** Usernames/passwords, session tokens/cookies, API keys, MFA codes, biometric data, cryptographic keys
 - **Payment card data:** Primary Account Numbers (PANs) must be unreadable in transit (PCI DSS requirement)
 - **Core principle:** Never transmit credentials or sensitive data over plaintext channels
- ▼ Network Segmentation & Isolation
- **What:** split network into zones by sensitivity to limit blast radius.
 - **Why:** stops attacker lateral movement (think fire doors).
 - **Strategies:**
 - **Zero-Trust / micro-segmentation:** "Never trust, always verify" – authenticate & authorize every connection.
 - **Perimeter (traditional):** VLANs, firewalls, ACLs.
 - **Key zones:** DMZ = buffer for public servers (web, mail, DNS) – no direct access to internal network.
 - **Practical:** apply least privilege between zones; log and monitor east-west traffic.
 - **Quick exam tips:**
 - TLS 1.3 + AES-GCM + **PFS** = ideal combo.
 - Disable weak ciphers (RC4/DES/3DES).

- Always encrypt credentials and tokens in transit.
- VPN = MFA + prefer always-on + cautious about split-tunnel.
- Network segmentation: **Zero-Trust** > **Perimeter** for reducing lateral movement.
- DMZ = public-facing buffer zone.
- Memorize the bold items for both practical use and exam questions.

| Merl Merean Nis Thaem TT

PDF 3 : Core Cryptography and Key Management

▼ Plan A : Understanding Cryptographic Fundamentals

▼ Only use encryption algorithm which has been tested by experts

- Password length : Minimum 112bits while Recommend 128 - higher
- Algorithm : AES, RSA and SHA-256
- Standard : Stay updated and monitoring vulnerable disclosures

▼ Modules and Service

- Use built in from OS and Stay updated
- Framework : TLS/SSL (openssl) | bcrypt, Argon2 | Cryptography.io
- Avoid Modification to fit your liking

▼ Understanding Cryptographic Constraints

- How long data remain value and the sensitive level
- Using short-term encryption for short-term data and the same goes to long one too both longer keys
- Benefit : Do not cost more than the data itself but to protect till it becomes worthless. (Value data which need to be cost more than itself is the data in uses everyday)

▼ Plan B : Cryptographic Key Lifecycle Management

▼ Restricting Access to Cryptographic Keys

- Make it known to little as possible and only neccessary
- Secure Key Storage : put in vault or HSMS
- Logs the key access every single actions

▼ Implement Key Separation and Strength

- Establish Key Hierarchy
 - Encrypt data (DEKS)
 - Key Encryption (KEKS)

- Security Strength should be KEKS > DEKS
- Physical/Logical Isolation
 - Store different place than DEKS
 - Use Different method for HSMS
 - Never Store KEKs alongside as DEKs
- Access Control
 - Different personnel, different KEKs
 - 2FA for KEKs access
 - Time-based Restriction
- ▼ Controlling Context
 - Separate Key so online when combine can unlock
 - Dual Control which need all member to activate at the same time
 - Document Procedure which needs to be follow accurately
- ▼ Managing Cryptoperiods and Key Changes
 - ▼ Key Duration
 - Session keys : Minutes to hours
 - Data Encryption Keys : Months to Years
 - Key Encryption Keys : 1-3 years
 - Root Key : 3-5 years
 - ▼ Implement Key Rotations
 - Set calendar and reminder to change key
 - Automate if possible
 - Test Rotation Procedure in non-production environments
 - Re-encrypt data with new keys before destroying the old one
 - Maintain key version tracking for IT audit
 - ▼ Handle Compromise Situations
 - Create emergency key replacement procedure
 - revoke all access immediately
 - Investigate scope
 - Re-encrypt all affected data with new keys
 - Notify stakeholders if required by law or regulation
 - ▼ Documenting Cryptographic Architecture
 - **Purpose:** Maintain detailed records of encryption setup for security, compliance, and incident response.
 - **Document:**

- Algorithms (AES-256, RSA-2048)
- Protocols (TLS 1.3, IPsec)
- Key strengths, usage, storage, backups
- Custodians and access rights
- **Environment separation:**
 - Use different keys for production vs test/dev
 - Label environments clearly
 - Block key migration between them
 - Prefer separate key management systems
- **Regular reviews:**
 - Quarterly inventory check
 - Annual audit
 - Update docs after changes
 - Track deprecated algorithms
 - Review access logs & custodian roles

Core idea: Proper documentation enables quick recovery and compliance.

▼ Plan C : Applied Data Protection Using Cryptography

▼ Encrypting Data in Rest

- Server and Database Encryption
 - Enable Transparent Data Encryption (TDE) on database
 - FDE on server
 - Encrypt sensitive asset at application layer
 - Implement encryption for backup
- End-User Device Encryption
 - Window : BitLocker
 - macOS : FileVault
 - Linux : LUKS or dm-crypt
 - Mobile : default built in encryption
- Cloud Storage Encryption
 - User server side for cloud storage
 - Consider client-side sensitive data to be extra encryption
 - Ensure keys are managed properly
 - verify provider's encryption practices

- CUI Protection
 - Follow government guideline
 - Maintain Compliance
- ▼ Encrypting Data in Transit
 - Goal: Protect data as it moves across networks using secure encryption protocols.
 - Web Traffic: Use TLS 1.3 (or 1.2 minimum) with HTTPS; strong ciphers only; disable weak ones; use trusted SSL/TLS certificates.
 - Remote Access: Use SSH for server management; use VPNs for remote users; replace FTP → SFTP/SCP; disable Telnet and legacy protocols.
 - Email Security: Use TLS for SMTP; S/MIME or PGP for end-to-end encryption; encrypt attachments with sensitive data; implement DMARC, SPF, DKIM for email integrity.
 - Payment Data: Encrypt PANs (card numbers) in transit; use P2PE when possible; never send card data over unsecured channels.
 - Internal Networks: Don't trust internal traffic; encrypt sensitive internal communications using IPsec or TLS; apply network segmentation + encryption for better isolation.
 - Core idea: Encrypt everything in motion – both external and internal – to prevent interception and data leaks.
- ▼ Protecting Authentication Factors
 - Never store as plaintext (must encrypt using algorithm)
 - Transmission must be over TLS/HTTPS and do not send credential over unencrypted chat
 - MFA using biometrics with strong encryption
 - Session must be over the time limit and manage thoroughly
 - Use PAM which only access to specific part of it instead all of it

PDF 4 : Define and Protect The Trusted Computing Base (TCB)

Section A : Core Security Design Principles

▼ Principle 1 : Layering

- Never rely on single layer security

▼ 3 Types of Control

- Prevention Controls : Stop attacks before that happen
 - firewall block virus
 - Controls which prevent unauthorized access
 - encryption data from being read
- Detective Controls : Identity when attacks are happening
 - Alert Monitor
 - Track what's happening in system
 - security audit to find vulnerable
- Corrective Controls : Fix problems after they occur
 - backup and restore data
 - patch and fix bug
 - incident response procedures that contain breach

▼ Principle 2 : Least Privilege

- Identify actual needs
- Grant minimal permissions
- Use access control systems
- Review regularly
- Remove unused access

▼ Principle 3 : Fail Securely (Secure Failure)

When Something break or crash, default action should be isolate and blocking access to protect resource rather than open it wide

▼ Principle 4 : Zero Trust/Trust But Verify

Always Verify Every Identity Which Try to Access and never trust anything at all before verifying

▼ Tradition Security vs Zero Trust

Name	Tradition Security	Zero Trust
1	strong defences at network edge	security everywhere
2	can move and trust freely inside	access is required and trust is never assumed but earn
3	You can go anywhere , the sky is the limit	Elevator which you only have the access to

▼ Core concept of zero trust

- No implicit trust : Don't assume internal internet as trustworthy
- Always authenticate
- Always Authorize
- Continuous verification
- Confinement

▼ To implement Zero Trust

- Required Authentication everywhere
- Implement micro segmentation
- Use identity based access
- apply confinement
- monitor continuously

▼ Principle 5 : Keep it Simple

▼ Concept

- Computing System Minimalism(don't use unnecessary hard/software)
- Rule of Least Power (Choose the best solution)
- Avoid feature creep (Something you don't need)
- Optimise resources

▼ Implementing Simplicity

- Start with requirements
- Choose appropriate
- Minimise dependencies
- Remove unnecessary components
- Use straightforward designs
- Document clearly

Section B : Classic Security Models

These are formal frameworks that define how information should flow securely in systems, they ensure confidentiality (no leak) and integrity

▼ Bell-LaPadula Model (BLP) Confidentiality Rules

- No read up : can't read data above level
- no write down : avoid leaks in less secure zone

┆ Prevent accidental or intentional leaks and classification errors

▼ Biba Model - Integrity Focus Rules

Prevent trusted data from corrupted system. Information move downward only, prevent low-trust input from affecting high-trust processes

- No read down : a trusted subject can't read lower-integrity data
- no write up : a lower trust subject can't write to higher integrity data

Model	Focus	Prevention	Rules	Flow detection
Bell-LaPadula	confidentiality	data leaks/info disclosure	No read up/no write down	up only
Biba	integrity	data corruption/tampering	no read down/no write up	down only

┆ Biba = No Read Down, No Write Up → integrity.

┆ Bell-LaPadula = No Read Up, No Write Down → secrecy.

Section C : Define And Protect The Trusted Computing Base(TCB)

Make them all work together to get the best security out there

▼ Component of TCB

- Hardware
- Software
- Firmware
- Controls

▼ The Reference Monitor (The heart of the TCB)

1. Tamperproof
 - a. Cannot be modified or disabled by attackers
 - b. protected from unauthorized changes
 - c. maintains its integrity even under attack
2. Always Invokable
 - a. can't bypass
 - b. access must go through
 - c. no backdoor or alt path
3. Correctly Implemented
 - a. works exactly as designed
 - b. no bugs nor flaws
 - c. enforce all security

▼ How to protect your TCB

1. Identify TCB components : Document everything that's part of your security foundation
2. Minimise the TCB : Keep it as small as possible (fewer components = fewer vulnerabilities)
3. Implement strong access controls : Restrict who can modify TCB components
4. Monitor for tampering : Watch for unauthorized changes to TCB elements
5. Verify integrity regularly : Use checksums, digital signatures, or other methods to ensure components haven't been altered
6. Audit thoroughly : Regularly review TCB configuration and operation
7. Isolate from untrusted components : Keep the TCB separate from less secure parts of the system

PDF 5 : Secure Architecture Principles and Practices

▼ Enforce Least Function and Secure Configurations

Only enable specific port, programs, services, protocols and function needed other than that, disable or remove. Protect vulnerability

▼ The Attack surface Concept

- The more attack interfaces you have enable, the more opportunities for attacker to attack

▼ How to implement least Functionality

▼ Conduct an Audit

- Test run all services and programs
- Documents all open network port
- List enable protocols
- List all installed application
- Review enabled system functions

▼ Identity Essential Functions

- Determined what needed for the operation
- Divide between "Must" and "Nice to have"
- Consult with users and stakeholders

▼ Disable Unnecessary Services

- Turn off not needed services
- Enable only needed
- Remove services that have secure alternative

▼ Remove Nonessential Programmes

- Remove app which not needed both trial and bloatware
- Get rid of redundant tools and outdated software

▼ Close Unused ports and block unneeded protocols

- config firewall to block ports which not using
- Disable network protocols which not needed (iv6 if not using)
- Use whitelist rather black list

▼ Secure Administrative Access

- Use secure alt (https instead http, SSH instead telnet) and MFA

▼ Documentation and Management

▼ Document Baseline Configuration

- Create and maintain the approved configuration
- Version control
- Create template for consistent deployment

▼ Implement Configuration Management

- Use tools which can automatically enforce baseline and detect configuration drift
- Restore and track all configuration changes

▼ Bottom Line

- If you don't need, delete it
- If you can't delete, disable it
- If you can't disable, Restrict it

▼ Manage Default Accounts and Settings

DO NOT USE DEFAULT CONFIGURATION , Must alter and fit your environments

▼ Why it's dangerous

- Public Documented
- Identical across ton of devices
- Indexed in attacker databases
- Target By Automated scanning tools
- The first thing attackers try

▼ How to Implement Default Account Management

▼ Step 1 : Create secure and approved standard configurations

- Document approved settings for each type of system
- Include security-hardening steps in your standard
- Base your standard on industry benchmarks (CIS Benchmarks, DISA STIGs, vendor hardening guides)
- Get stakeholder approval for the standard
- Keep the standard updated as threats and technology evolve

▼ Step 2 : Address Default Accounts

- For accounts you can disable
 - Disable built-in accounts (administrator, root, admin, guest) and create new administrative accounts with unique, non-obvious names. Document which accounts are disabled and why.
- For accounts you cannot disable
 - Change passwords to extremely strong ones (long, random, complex), set restrictive account policies (e.g., deny login rights), limit

login locations, and closely monitor for any usage attempts.

▼ Change Password And Secure Settings

- Change all default passwords immediately
 - Never leave factory passwords in place
 - Don't use simple variations of defaults (admin123 is not better than admin)
 - Use strong, unique passwords for each system
 - Consider using a password manager for administrative credentials
 - Implement a policy that forces password changes during initial setup
- Secure default settings
 - Change default SNMP community strings (public/private)
 - Modify default database ports (though obscurity isn't security, it adds a small layer)
 - Adjust default file sharing settings (often too permissive)
 - Review default firewall rules (often allow too much traffic)
 - Update default encryption settings (often use weak or outdated algorithms)

▼ Maintain Configuration Consistency

- Step 5 : Apply standard, tools to enforce consistency both with export image of it and make it automatically activate instead of manually
- Step 6 : Continuously verify system configurations against a secure standard, checking for unauthorized drift and reviewing changes using automated compliance monitoring tools.

▼ Quick Wins for Default Management

1. Change every default password on every system
2. Disable or rename default administrative accounts
3. Create a one-page quick reference guide for your secure configuration standard
4. Run monthly scans to identify systems still using defaults
5. Make secure configuration mandatory in your procurement and deployment processes

▼ Terminate Inactive Connections

| Automatically Close Network Connection when not used (Don't Idle)

▼ Type of Connections to Manage

- User Sessions : Web Applications, Remote Desktop, VPN connections
- Database Connections : Application-to-database links
- Network Connections : TCP sessions, SSH sessions, Telnet sessions
- API sessions : REST API tokens, authentication sessions

▼ How to Implement Connection Termination

- **Define Timeout Policies:** Establish appropriate timeout periods by considering security requirements, data sensitivity, business needs, and compliance regulations (→ e.g., high-security systems often use 5-10 minutes of inactivity).
- **Implement Session Timeouts (Web Apps):**
 - Configure idle timeout for both the session cookie and server-side session.
 - Display a pre-timeout warning to users.
 - Require re-authentication after timeout.
- **Implement Network & Remote Access Termination:**
 - Configure keep-alive timers and TCP timeout values for network connections.
 - Set RDP/VNC session timeout policies and VPN idle disconnect timers for remote access.
 - Implement SSH timeout settings.
- **Manage Database Connections:**
 - Set connection pool timeout values.
 - Configure idle connection reaper threads.
 - Implement application-side connection management.

PDF 6 : Secure Network and Communications Architecture

▼ Main Goals

- Create Strong boundaries to separate from the outside world
- Control where data can flow and not as security checkpoint
- Use encryption to provide confidentiality

▼ Core Competencies (Skill gains)

- Network Segmentation

- Isolate sections
- Put sensitive system separately
- Attacker can't reach the network from out network
- Firewall Management
 - Set firewall rule to block access to unauthorized person
 - While Ensuring People within are safe
- Defence-in-Depth
 - Put Multiple network layer so if one break
 - Other can replace it instantly
- Data Encryption
 - Encrypt data with strong algorithm
 - Even attacker got it, they can't open nor read its content

Part 1 : Understanding and Organising Your Network

▼ Security Blueprint : Three Key Steps

▼ Create Comprehensive Network Diagrams

- What to do : Draw devices connected to network in details
- What to include
 - Servers
 - Employee Computer
 - Router
 - Switches
 - IoT
 - Etc
- The Technical Details : Document how they are connected logically and their IP both with Vlan

▼ Map Data Flow Diagrams (DFDs)

- Where the data → Enter → Proceed → Stored → Transmitted From one place to another
- Find where to protect the most and help to find vulnerability

▼ Maintain Living Documentation

- Update Diagram Immediately when change (add, remove, modify or connection)
- Follow Updated Documentation to be secure and align with standard
- Set up formal change management process to make sure documentation is always accurate

▼ Segmentation : Separate rooms with locked doors and security checkpoints

▼ Define Security Scope

- Identify which systems handle sensitive data of users
- Document the scope definition
- Review and update whenever major event occurs or a time per year

▼ Create Network Boundaries

- Firewall as locked door or checkpoint between segmentation
- Control and monitor those access which has been authorized

▼ Why Segmentation is Essential

- Limits Attacker Movement : slow down with multiple layer firewalls
- Reduce Compliance Costs : Reduce time and money
- Enable Targeted Security : Apply the most security to the most sensitive data and have their access under controls

▼ Testing Requirements

- Conduct a Penetration testing twice a year on firewall and routers and create segmentation barriers
- Test extra for more major changes
- Document all finding after penetrated to report vulnerable and how to fix them
- Use Qualified Professionals with Certification to conduct

▼ Why it's Essential

- Rules might change overtime bit by bit without anyone knowing
- Mistakes or more can be occurred during setup or maintenance
- Small changes can lead to bigger problems and consequences

Part 2 : Controlling Network Traffic With Precision

▼ Main Cores

- Block Unwanted Incoming Traffic : deny inbound connections
- Block Unwanted Outgoing Traffic : prevent data exfiltration and malware communication
- Protect Public Systems : DMZ isolation for exposed services

▼ Default Deny

| Use Whitelist instead of Blacklist

▼ incoming traffic control

- Document all incoming connections like address, destination ports...

- Build Firewall which permit only the allowed legitimate traffic
- Set Default Deny Policy which ensure that these denials are logged to monitor for potential attacks
- ▼ outgoing traffic control
 - Data Exfiltration: It prevents attackers, even after a system is compromised, from stealing data by blocking unauthorized outgoing connections.
 - Malware Communication: It disrupts malware from communicating with command-and-control (C2) servers to receive instructions or transmit stolen information.
- ▼ DMZ architecture
 - | Implement 2 firewalls which are external and internal
 - ▼ Purpose
 - When Attack break through external firewall, they have to face with internal one to get to the server buying time to respond
 - Architecture
 - | Internet → External FM → DMZ → Internal FM → Secure Server

Part 3 : Secure Communications and Protocol Management

- ▼ Main Core
 - ▼ Encryption for Data Transmission
 - Always encrypt sensitive data and use secure protocol like
 - SSH
 - HTTPS
 - TLS/SSL
 - ▼ Eliminate Insecure Protocols
 - Replace and Update outdated protocols with modern to avoid
 - credential theft
 - data exposure
 - ▼ Regular Security Reviews
 - Conduct systematic reviews twice a year to ensure effectiveness and well maintenance
- ▼ Security Foundation
 1. Document all comprehensive and current data flow as you can not secure what you don't understand

2. Segmentation can reduce and limit the damages as it's within its own scope and to be controlled to each sensitive level
3. Default deny is your friend as it block everything except what is explicitly allowed reducing the risk on the surface
4. Encryption is non-negotiable and strong encryption protocols are needed like SSH, HTTPS, TLS ... to eliminate security risks
5. Regular reviews are essential as it's to keep the firewall rule and maintenance updated to avoid being exploit or can't keep with the traffic flows

PDF 7 : Incident Response Operations and Disaster Recovery

▼ What is Incident Response

| Procedure to carry out when there's

- Security Breach
- Cyberattacks
- System Failures

▼ IR (Incident Response) Plan

- Preparation : Create team, roles and procedures before incident occur
- Detection : Identify when security or system failure happen
- Analysis : Understand scope impact and severity of the incident
- Containment : Isolate and stop the problem from spreading
- Recovery Systems : Restore systems services to normal operations
- Post-Incident Review : Document and report to fix improve future IR

▼ Real-World Scenario: Website Down

| When a website down, what are the questions needed to be ask ?

- Who get notified first ? IR team
- What log should you check ? Identify system logs and traffic patterns
- Attack or Technical Glitch ? Distinguish between malicious activity and system failures
- How do I isolate affected system ? Document containment procedure to prevent it spreading

- How do you communicate with customers ? Prepare messaging template to announce

▼ Assigning Response Team Roles

- IR lead
- IR backup lead
- Technical Analysts : Investigate and fix errors
- Communications Coordinator : Sum up and Tell the head management
- Legal/Compliance Officer : Ensure regulatory requirements are met

▼ Train and Testing Your Team

▼ Tabletop Exercises : Make up scenario and test decision making

- Focus on procedures and communication
- low-cost, easy to conduct
- Ideal for identifying gaps in plans

▼ Simulations : Technical Drills in environments

- Validate technical capabilities
- Moderate complexity and cost
- Reveals tool and access issues

▼ Full-Scale Tests : Real world accident responding

- Most Comprehensive validation
- High cost and coordinate needed
- Build team confidence and muscle memory

▼ Sample Tabletop Exercise

It's 2AM and you are alerted someone in Russia attempted to log in from 30 minutes ago

- Can team members access the IR plan after hours ?
- Do they have the right tool and permissions ?
- Are their contact lists available ?
- How quickly can critical decision be made ?
- Are communication channel established ?
- Do team members know their specific roles ?

▼ Incident Containment Strategies (Immediately)

▼ malware/Ransomware

- Isolate infected systems
- Disable compromised accounts
- Block malicious IP address
- Preserve Evidence for forensics analysis

▼ Data Breach

- Revoke Compromised access credentials
- Identify and scope exposed data
- Secure backup systems to prevent further compromise
- Document the breach timelines

▼ DDoS

- Activate DDoS mitigate services
- Reroute traffic through scrubbing centres
- Communicate with ISP
- Scale resource to absorb all the traffic

▼ Post Incident Reviews

1. Timeline Reconstruction
 - a. Create detailed incident how it happened
2. Response Evaluation
 - a. Assessing of what worked well and not focusing on effectiveness
3. Root Cause Analyst
 - a. Identify why the incident happen in the first place to improve
4. Impact Assessment
 - a. Calculate financial, reputational, and operational costs
5. Improvement Actions
 - a. Define specific changes to prevent recurrence

▼ Logging And Monitoring

┆ Monitoring is having someone watch over the camera for 24/7

▼ Create Audit Log Management Process

▼ Log Collection Requirements

- System must generate logs
- Information contained

- How logs collected and stored
- Who can access to logs
- ▼ Log Review Requirements
 - How review logs often
 - Look for failed login, privilege escalations
 - Find suspicious things
- ▼ Log Retention Requirements
 - How long the logs takes
 - Where the logs stored
 - Payment system requires 12 months
- ▼ Time Synchronisation (Important for accuracy)
 - All systems use the same source
 - Filter the least problematic
 - Enable time accurate reconstructions
- ▼ Essential Log field and data types
 - Time stamp
 - User identity
 - Source IP address
 - Action Performed
 - Result
 - Data Affected
- ▼ Additional Log Type
 - DNS Query Logs
 - Command-Line Audit Logs
 - Application Logs
- ▼ Centralising and Analysis Logs
 - SIEM Tools
 - Open-Source Platforms
 - Cloud Logging Services
- ▼ What for ?
 - Brute force attack
 - Login location
 - potential data theft
 - admin account data usage

▼ Data Recovery And Business Continuity

▼ Plan Data Recovery Process

- RTO (Recovery Time Objective) : How quickly a system must be restored
- RPO (Recovery Point Objective) : The maximum amount of data loss that is acceptable

▼ Implement Automated Backups

▼ Full Backup

- Complete copy of data
- Pro : Simple to store and complete protection
- When : Weekly or Monthly

▼ Incremental Backup

- Only change since last backup
- Pro : Fast and efficient storage
- When : Daily Combined with weekly backup

▼ Differential Backup

- Changes since last full backup
- Pro : Faster restoration than incremental
- When : Alternative for medium-sized datasets

▼ 3-2-1 Backup Rules

- 3 Copies of Your Data : Original + 2 Backups
- 2 Different Media Types : Local disk plus cloud storage
- 1 Copy off-Site : Protect against physical disasters

▼ Testing and verification Recovery

- Quarterly : Partial file restores
- Semi-Annually : Single System Recovery Test
- Annually : Full disaster recovery simulations

▼ Path Forward

▼ Preparation

- Create
- Document

- Regularly Test Response
- ▼ Detection
 - Using comprehensive logging
 - Automated to monitoring spot threat early
- ▼ Response
 - Act quickly and adapt to plan
- ▼ Recovery
 - Rely on backup regularly
 - Prioritize the most important system file
- ▼ Improvement
 - Treat every incident as chance to learn and develop
 - Update security and proecedure

PDF 8 : Secure Software Development Lifecycle

PDF 9 : Data Compliance A Practical Guide

Part 1 : Basic Governance Requirements

Principle	Practice
Legality : Have legal basis of what you doing	Don't Collect more than needed for business purposes
Propriety : Handle Data Appropriately and fairly	Be clear about why you need each of the information
Necessity : Only collect what needed	Choose methods that have least impact on people privacy
	Keep data accurate to avoid harming individual

▼ MLPS (Multi layer Protection Scheme)

This ensures baseline cybersecurity protection and helps you respond effectively to security incidents

▼ Conduct Regular Compliance Audits

1. Audit Annually
2. Review all personal information processing activities
3. Check compliance against relevant regulations
4. Document findings and remediation actions
5. Keep audit records for at least 3 years

▼ Clarify Joint Processing Responsibilities

- Identify Joint Processing : Find all scenario with other organization
- Create Written Agreements : Specify responsibilities and rights
- Accept joint Liability : Both parties are joint liable with the agreement in place

Part 2 : Risk Assessment (PIPIA)

A **Personal Information Protection Impact Assessment (PIPIA)** is a mandatory self-assessment you must conduct *before* engaging in high-risk data processing

▼ PIPIA Requirements (Report Must Be Kept 3 Years)

- Transferring any personal data **overseas**.
- Processing **sensitive data** at a large scale.
- Using data in ways that significantly **affect individuals' rights**.
- Publicly disclosing personal information.

▼ Sensitive Data (Requires Extra Protection)

- Rule : You must get **separate, explicit consent** to process sensitive data and apply stronger security controls.
- Type of Sensitive data
 - **Biometric**: Fingerprints, facial recognition
 - **Financial**: Bank accounts, transaction records
 - **Location**: GPS, movement tracking
 - **Health**: Medical history, diagnoses
 - **Religious Beliefs**
 - **Personal ID Documents**: Passport, ID numbers

Part 3 : Cross-Boarder Data Transfers

You may need to apply to the **Cyberspace Administration of China (CAC)** for a security assessment *before* you can transfer data abroad.

▼ CAC Assessment Mandatory when

- You are a **CIIIO** (Critical Information Infrastructure Operator).
- You transfer data **exceeding volume thresholds** set by the CAC.
- You transfer **"Important Data"** (related to national security, economy, etc.).
- Your activities might **affect national security**.

▼ The Approval Process

- **Complete a Self-Assessment First:** Before applying to the CAC, you must conduct your own detailed risk assessment. It must evaluate:
 - The legality and necessity of the transfer.
 - Risks to national security and individual rights.
 - Whether the **overseas recipient** can adequately protect the data.
 - How individuals can still exercise their rights.
- **Prepare a Complete Application:** Your formal application to the CAC must include:
 - Application form (detailing the business purpose, data types, etc.).
 - Your **Self-Assessment Report**.
 - A **Letter of Commitment**.
- **Establish Strong Contractual Protections:** You must have a legally binding contract with the overseas recipient that includes:
 - Clear data security responsibilities.
 - Data breach notification procedures.
 - Audit rights (allowing you to check their compliance).
 - A clause ensuring compliance with Chinese law.
- **Disclose Your Compliance History:** You must be transparent with the CAC about your track record, including:
 - Any administrative penalties from the **past 2 years**.

- Any regulatory investigations and their outcomes.